

APKGraph v2.0 - Overview

Android Attack Surface Intelligence Platform

APKGraph has been vastly upgraded to v2.0. It is a high-efficiency Mobile Application Security Testing (MAST) platform designed to transform Android applications into a complete attack surface graph. Instead of producing thousands of isolated findings, APKGraph correlates components and predicts potential attack paths.

New Features in v2.0:

1. Hybrid Dynamic Execution (Auto-Pwn)

Bridges the static-to-dynamic gap. APKGraph now automatically targets hardcoded AES/XOR string decryption routines, generates a custom JavaScript payload (`apkgraph_deobf_hook.js`), and automatically orchestrates `frida` over USB/ADB to hook your live Android application and dump decrypted strings to the console in real-time.

2. Cross-Boundary Taint Tracker (Dalvik -> Native C++)

Standard decompilers lose track of Intent data the second it enters `native` code. APKGraph v2.0's Depth-First Search engine natively reads Dalvik access flags (`0x0100`). It automatically maps vectors where DeepLinks, Content Providers, and Intents flow directly into `[NATIVE_JNI_SINK]` methods, immediately flagging them as Critical for Memory Corruption and Command Injection hunting.

3. Cross-Platform Engine

Automatically rips open `index.android.bundle` (React Native) and `Cordova/Ionic` JavaScript asset bundles. It parses these UI assets to find hidden REST API routes, GraphQL endpoints, AWS Secrets, and JWTs which are usually missed by standard Java scanners.

4. Automated Backend Probing & Fuzzing Generation

Generates two actionable artifacts for your live testing: 1. `_endpoints.txt` : A clean dictionary of every backend route. 2. `_backend_scan.sh` : A pre-formatted BASH script ready to be fed directly into `ffuf` or `sqlmap` to fuzz the application's backend architecture. 3. `intent_fuzzer.py` : Generates custom Android Intents for all exported activities/services on the device via ADB.

5. Native Binary (.so) Extractor

Analyzes `.so` ARM ELF binaries using embedded Regex and YARA signatures to detect API keys baked into C++ libraries.

6. Next-Gen Reporting

The CLI now defaults to a single, easily portable HTML output. The HTML report features beautifully styled collapsible cards containing the vulnerability explanation, CVSS scoring, and exact copy/paste reproduction code snippets for your PoCs.